ChatGPT in Microsoft 365

Access restriction, risks and recommended checks

Work completed

On 12 October, sign-in to the ChatGPT enterprise application was restricted to a dedicated Entra ID security group. Only members of that group can now sign in and use ChatGPT with their CB Civil account. Everyone else is blocked at sign-in. Membership is limited to the approved users.

Summary

ChatGPT's Microsoft 365 permissions let it act as the signed-in user, so it can only reach what that user can already access. The main risk is oversharing: content that is technically open to many people but rarely found becomes easy to discover through a chat. We recommend the checks below before the group is widened.

Key risks

Risk	Why it matters	Rating
Oversharing in SharePoint and OneDrive	ChatGPT can surface any file a user can open, including content shared too broadly.	High
Meeting recordings and transcripts	Stored as ordinary files, and access may be wider than the attendees. They often contain sensitive discussions (HR, commercial, client).	High
Write access (calendar, contacts, tasks, Teams messages)	The app can create or change data as the user, not just read it.	Medium
Directory-wide read access	Exposes organisational structure and group membership to the app.	Medium
Group membership drift	The approved group can grow without review.	Low to medium

Recommended checks

Before widening access

1. Run SharePoint Advanced Management sharing reports (org-wide links, "Everyone except external users", site permissions).
2. Check that meeting recordings and transcripts aren't shared more widely than the attendees (for example via org-wide links or broad channel and site membership).
3. Review Entra sign-in logs to confirm only group members are signing in.
4. Require SSO for the company domain on the ChatGPT side where possible, so users can't sign in another way (see the ChatGPT admin section).

Ongoing

5. Quarterly access review, with a named group owner.
6. Monthly review of sign-in and audit logs.
7. Extend sensitivity labels and DLP.
8. Re-review when new connectors appear.

Decisions needed from the business

- Who owns the group and approves members?
- Should transcript access stay on, and for whom?
- Target date for fixing any oversharing found?

For the ChatGPT admin (ChatGPT Business)

The Entra change controls who can sign in through Microsoft. It is only a complete control if everyone with a CB Civil email has to sign in through Entra. On ChatGPT Business, the workspace owner does this under Identity & provisioning, in this order.

1 Verify the company domain

- Add and verify the CB Civil domain under Verified Domains, using a DNS TXT record. Whoever manages the CB Civil DNS will need to add it.
- OpenAI's troubleshooting guidance gives a 7-day window to complete a verification attempt.
- A domain can only be verified in one OpenAI admin portal. If another workspace or tenant already holds the domain, contact OpenAI Support before changing anything.

2 Set up SSO with Entra ID

- Select Set up SSO and choose SAML or OIDC (Business supports both), then configure the Entra enterprise application, which is where the group assignment sits.
- Test with an assigned user before inviting anyone else.
- Invite members using the same email as their existing OpenAI account, or they may end up with a second account and lose their chat history.

3 Require SSO and confirm there is no other way in

- OpenAI's Business SSO guidance doesn't describe a dedicated Enforce SSO toggle. It says the SSO requirement applies to the email domains covered by the workspace's sign-in policy. Check what the workspace offers.
- Test with a CB Civil user who is not in the Entra group, trying SSO and then a password or social login.
- If SSO cannot be required for the domain, the group restriction is only partial. Record this as a known gap.

Before changing sign-in requirements

- Have a second owner or recovery method, and transfer ownership before the only owner leaves.
- Make sure the admins have a working SSO login and are in the Entra group, and renew signing certificates before they expire.
- Tell users in advance. Anyone using a password or social login may be moved to SSO.
- Decide whether automatic account creation (optional on Business, works independently of SSO) and external domain invites should be on.

OpenAI documentation (Business)

SSO for ChatGPT Business FAQ	https://help.openai.com/en/articles/11489188-sso-for-chatgpt-business-faq
Verifying your domain for OpenAI Identity	https://help.openai.com/en/articles/8871611
SSO overview (ChatGPT and API Platform)	https://help.openai.com/en/articles/10468051

OpenAI updates its admin screens often, so check the current wording on the live pages before starting.

If CB Civil upgrades to ChatGPT Enterprise

CB Civil is on ChatGPT Business today, so nothing on this page needs actioning now. It is here for planning, because an upgrade would change several of the controls above.

1 Enforce SSO becomes a dedicated setting

- Global Admins can set Enforce SSO to Required from the Manage SSO page. Users with the verified domain can then only log in through SSO, and social login is disabled for provisioned users on a verified domain. This closes the gap noted in step 3.

2 Directory provisioning becomes available

- A standalone Business plan has no SCIM or automatic directory provisioning. Enterprise offers it, so ChatGPT membership could follow an Entra group instead of being managed by hand inside ChatGPT.

3 SSO and domains are shared with the API Platform

- On Enterprise, the same SSO connection and domain verifications cover the ChatGPT workspace and API Platform organisations, although SSO is enabled separately for each.

4 Plan the migration with OpenAI first

- Review migration options with the OpenAI account team before upgrading or cancelling Business. Users may be offered a transfer of chat history and GPTs, and existing accounts need to be handled so nobody ends up with duplicates.

5 Re-test the Entra controls after the move

- Confirm the enterprise application, group assignment and Assignment required setting still apply, and repeat the member and non-member sign-in tests. Review the permissions on any new connectors at the same time.

OpenAI documentation (Enterprise)

Identity and provisioning in ChatGPT Enterprise and Edu	https://help.openai.com/articles/9672121
SSO overview (ChatGPT and API Platform)	https://help.openai.com/en/articles/10468051
Login, SSO, SCIM and domain verification FAQ and troubleshooting	https://help.openai.com/en/articles/10489721